Reto 02
Registro de contratos vigentes

Automatización administrativa con IA, trazabilidad y revisión humana.

Aplicación	https://reto-contratos-ia.vercel.app
Repositorio	https://github.com/marcossere-maker/reto-contratos-ia

1. El problema y la propuesta

El registro de contratos depende de correos dispersos y carga manual. Cuando los documentos no llegan a Administración, el maestro queda incompleto y resulta difícil anticipar vencimientos y pólizas. La propuesta combina un agente que procesa lo recibido con una regla de gobierno que define responsables, plazos y excepciones.

2. Qué hace el agente

Recibe una instrucción por chat. Por ejemplo: “Revisá el buzón, registrá los casos claros y consultame antes de completar datos dudosos”. Qwen interpreta el pedido y solicita las herramientas; el backend ejecuta y controla cada operación.

Procesa y clasifica. Extrae cliente, identificación, monto, fechas y garantías; contrasta con el maestro y distingue contratos nuevos, modificaciones, duplicados y adjuntos que no son contratos.

Registra o consulta. Los casos claros se incorporan o actualizan. Los campos ausentes, ambiguos o en conflicto quedan pendientes para una confirmación explícita del usuario.

Deja evidencia. Conserva documentos, historial y mensajes procesados, permite descargar el maestro CSV y produce alertas de vencimiento y pólizas.

3. Alcance de esta entrega

En funcionamiento	App pública en Vercel; Qwen real mediante Groq; herramientas y validaciones; confirmación humana; datos y sesiones persistentes en Supabase.
Simulado en el reto	Buzón de seis correos y adjuntos TXT ficticios. El archivo representa una estructura tipo SharePoint. No hay conexión a Gmail, Outlook ni SharePoint corporativo.

4. Cómo probarla

Abrir la app y pulsar **“Revisar los 6 correos de ejemplo”**. Mirar la tabla de resultados y el caso que necesita revisión. Para repetir desde cero, **“Reiniciar datos de prueba”** restablece únicamente tu espacio ficticio. Luego se pueden descargar el maestro y las alertas.

El valor propuesto es reducir la transcripción y concentrar la revisión humana en las excepciones. Los ahorros de tiempo todavía deben medirse en un piloto.

Controles, evidencia y evolución

PERSONA Chat y revisión	AGENTE Backend + Qwen	HERRAMIENTAS Validación y registro	SUPABASE Estado persistente

5. Decisiones que sostienen el control

Valores con fuente. Extracción y reglas deterministas, con evidencia por campo. La confianza es una puntuación heurística, no una probabilidad calibrada.

Confirmación real. El modelo no autoriza escrituras dudosas. El backend verifica la confirmación vinculada al caso y vuelve a validar los datos.

Persistencia y credenciales. Supabase conserva documentos y sesiones en un snapshot transaccional con control de versión, probado entre publicaciones. Las claves quedan en el backend y fuera del repositorio.

6. Casos verificados

Caso	Resultado
01 - Nuevo con póliza	Registro; póliza pendiente de acreditar vigencia.
02 - Contrato nuevo sin póliza	Se registra con póliza “no aplica”.
03 - Otrosí	Actualización e historial de diferencias.
04 - Reenvío duplicado	Se marca procesado, sin crear otra fila.
05 - Cotización	Rechazo como entrada de contrato, con motivo.
06 - Contrato por demanda	Sin registrar: requiere confirmar monto y fechas.

Caso 06: para ensayar, confirmar valor 0, inicio 31/08/2026 y fin 31/08/2027. Son supuestos del operador para la demo; el documento no contiene el día exacto de firma.

7. Gobierno y medición del proceso

Administración es dueña del maestro; **Comercial** envía documentos firmados al buzón único dentro de dos días hábiles. Asignar y escalar excepciones, y conciliar contra facturación para detectar faltantes.

Indicador: porcentaje de contratos facturados con documento y registro vigente. Medir también antigüedad de pendientes, tasa de revisión y tiempo por caso. Acordar la meta tras establecer la línea base.

8. Verificación y siguiente etapa

Pasaron **11 pruebas automatizadas**, con cobertura funcional y de seguridad. Qwen real, la confirmación humana y la persistencia cloud se verificaron por separado. La app informa los límites de cuota de Groq.

Para producción: conectar correo y PDF/OCR; definir usuarios, respaldos y un esquema para mayor escala; ejecutar un piloto. Vertex AI o Bedrock requieren otro adaptador y pruebas: todavía no están integrados.

Uso de IA: Codex/ChatGPT asistió en implementación, pruebas y documentación. El candidato utilizó Claude para una revisión externa; sus hallazgos y correcciones se detallan a continuación y en REVISION_SEGURIDAD.md.

Del análisis a las correcciones

El informe de Claude revisó la página, JavaScript y respuestas HTTP mediante caja negra, sin acceso al backend ni a la base. Sus observaciones se contrastaron con el código antes de implementar cambios. El enlace privado de ese informe no se publica.

9. Hallazgos y respuesta aplicada

Observación original	Verificación y respuesta
Alta - Reinicio público	El literal de confirmación no era un secreto. Ahora el reinicio exige la cookie firmada del visitante y solo afecta su espacio, con límite de frecuencia.
Alta - Descargas abiertas	Maestro y alertas requieren la capacidad del visitante. Consultan su snapshot; sin cookie, la API responde 401.
Media - Escritura y gasto de IA	Ya existía validación contra documentos y cuotas en memoria. Se agregaron contadores atómicos en Supabase por IP, visitante y día, y un cupo global de solicitudes. El acceso anónimo sigue siendo deliberado.
Media - Sesión por identificador	Los UUID ya eran aleatorios. Se vinculó cada conversación y confirmación al espacio del visitante: conocer el UUID de otra persona no permite acceder.
Baja - Protección del HTML	CSP y bloqueo de iframe, junto con otras cabeceras, se aplican en Vercel y Express, incluidos errores de JSON.
Baja - CORS y falsos 200	Origen estático restringido, POST de otro origen rechazado y respuestas 404 reales. El informe no encontró una clave en /.env: antes recibía el HTML de inicio.
Informativa - Detalle técnico	Health público solo informa disponibilidad. El modelo y la actividad se muestran dentro del espacio propio para explicar la IA y aportar la evidencia pedida por el reto.

10. Recomendación adicional: CSV seguro

La descarga neutraliza celdas que podrían ejecutar fórmulas al abrir el CSV, incluso con espacios o controles iniciales. Este ajuste no modifica los valores del maestro canónico.

Estado: correcciones orientadas al alcance de la demo. No equivalen a una auditoría exhaustiva ni a certificar el uso con contratos reales.

Demo pública, datos separados

11. Cómo conserva los datos de cada visitante

Al abrir la app, el servidor emite una cookie aleatoria y firmada, HttpOnly y Secure en Vercel. El backend deriva el espacio desde esa capacidad; el navegador no elige un identificador de otro usuario.

Supabase conserva una fila por visitante con maestro, documentos, historial y confirmaciones propios. La cookie permite recuperar ese espacio durante siete días. Borrar cookies pierde el acceso; la expiración no elimina automáticamente los datos de la base.

El entorno compartido anterior se conserva para administración y no se sirve a visitantes. Las claves de Groq y de almacenamiento siguen exclusivamente en el backend. RLS exige la capacidad de servidor; el aislamiento entre visitantes se aplica en la API.

12. Evidencia y límites de las pruebas

Comprobación	Evidencia
Suite automatizada	11/11 pruebas: seis casos funcionales, valores con fuente, confirmación de un solo uso, persistencia reconstruida, firma y expiración, exportación CSV y recorrido HTTP de seguridad.
Dos visitantes	Se verifica que una sesión y su confirmación no se pueden usar desde otro espacio, y que reiniciar un espacio no borra el de otra persona.
API y publicación	Se comprueban descargas sin cookie, rechazo de otro origen, cabeceras ante JSON inválido y rutas inexistentes. El registro actualizado de las comprobaciones cloud está en VERIFICACION.md.
Base y secretos	Migración aplicada en Supabase; asesor de seguridad sin avisos. Escaneo del repositorio e historial sin la clave de Groq ni archivos .env.

13. Qué falta antes de producción

Identidad y permisos: autenticación corporativa, roles por organización, revocación y registro de accesos. La capacidad anónima de esta demo no prueba la identidad de la persona.

Operación: retención y borrado, respaldos y restauración, monitoreo de abuso y presupuesto del proveedor. La demo admite hasta 50 espacios; sus cuotas pueden agotarse. El tope global es de 100 solicitudes de chat por día, no de tokens.

Datos y gobierno: revisar con Seguridad y Administración qué información se enviará al modelo, incorporar correo/PDF y evaluar calidad con un piloto. Mantener la responsabilidad humana sobre excepciones y registro.

Fuentes técnicas: documentación de RLS de Supabase, cabeceras de Vercel y escape_formulas de CSV Stringify. Referencias enlazadas y matriz completa en REVISION_SEGURIDAD.md del repositorio.